

RBAC & Permissions Matrix

InfusioTech Restaurant Ordering SaaS | Version 1.0 | 2 October 2026

Purpose

Defines role templates and owner-managed permission controls for the shared restaurant mobile app.

Permission Keys

- orders.view, orders.accept, orders.reject, orders.cancel, orders.status.update
- tables.view, tables.manage
- payments.view, payments.cash.record, payments.reconcile, payments.refund
- menu.view, menu.create, menu.edit, menu.price.edit, menu.availability.edit
- customers.view, customers.export
- analytics.basic.view, analytics.advanced.view
- staff.view, staff.invite, staff.manage
- settings.manage, subscription.manage, ownership.transfer

Default Role Templates

- Owner: all tenant-level permissions. Ownership transfer and tenant deletion require additional confirmation and protected server workflow.
- Manager: orders and tables operations; menu and staff permissions only if granted by owner; reports according to assigned access.
- Waiter: view assigned/all permitted orders, update allowed statuses, view tables.
- Cashier: view orders and payment state, record cash received and reconcile only if granted.
- Kitchen Staff: view kitchen queue and update preparing/ready statuses only.

Owner Controls

- Owner can invite staff, select a template, grant/revoke eligible permissions, suspend/reactivate accounts and revoke access.
- Owner may create custom role templates. Permission changes must show a summary and require confirmation for high-impact permissions.
- Owner-only protected capabilities cannot be granted to ordinary staff by simple override; define an explicit privileged delegation policy if needed later.

Enforcement

- Compute effective permissions on server from active membership, role grants and valid overrides.
- Deny by default. Apply tenant and optional branch/assignment constraints in addition to permission keys.
- Invalidate or refresh active sessions/claims after permission changes; server must read current authorization state for sensitive actions.
- Audit actor, target membership, changed permissions, tenant, timestamp and request id.

Acceptance Tests

- Waiter cannot edit menu price unless explicitly granted and policy allows it.
- Kitchen staff cannot view customer exports or subscription settings.
- Cashier cannot mark an online payment paid manually.
- Revoked membership cannot call protected endpoints.
- Tenant member cannot access another tenant's records by changing path or payload IDs.